Threat Hunting na Prática

Como achar um invasor que nenhum alarme viu



Sidnei Barbieri · Ágney Lopes Roth Ferraz

ITA · Time Hikari · Orientação: Lourenço Alves Pereira Júnior

Hoje, você vai ser detetive

1 · Entender: o que é um evento, uma ameaça, um alarme e uma caçada.

2 · Conhecer a ferramenta: filtrar, contar e seguir a pista.

3 · Praticar: investigar um ataque numa empresa fictícia, passo a passo.

À tarde, a mesma plataforma recebe a Arena da 1ª Ciber Week Brisanet.

Parte 1

O básico



Tudo o que fazemos deixa rastro

Cada ação vira uma linha registrada em algum lugar: na portaria, no banco, no celular.



Catraca do prédio

`08:02 · crachá 4471 · entrada · portaria B`



Cartão de crédito

`12:41 · R$ 38,90 · restaurante · aprovado`



Celular

`21:15 · Wi-Fi de casa · conectado`

Um evento é o registro de algo que aconteceu

Ele responde a perguntas simples: quando, quem, o quê, com que resultado e de onde.

COMO UMA PESSOA CONTA

05:17 • c.moura • entrou na VPN • sucesso • 203.0.113.77

COMO O SISTEMA REGISTRA

CAMPO	VALOR	SIGNIFICA
@timestamp	2026-03-10T05:17:43Z	quando
user.name	c.moura	quem
event.dataset	vpn	o quê
event.outcome	success	resultado
source.ip	203.0.113.77	de onde



Ameaça é intenção de causar dano

Alguém, ou um programa, tentando roubar, espionar, travar ou se passar por outra pessoa.

Um evento sozinho não é ameaça. O mesmo registro pode ser rotina ou ataque.

Quem decide é o contexto.

O mesmo evento, duas histórias

O EVENTO

A conta `sidnei` errou a senha 3 vezes



CONTEXTO A

Sidnei voltou de férias hoje e esqueceu a senha.

Pediu ajuda ao suporte, trocou a senha e entrou.

Normal



CONTEXTO B

Sidnei está de férias, longe do trabalho.

As tentativas vêm de outro país, às 3h da manhã.

Alguém tenta a senha dele

Normal ou suspeito? Depende de quem, quando e por quê

EVENTO	NORMAL QUANDO É...	SUSPEITO QUANDO É...
Download de 10 GB	o backup automático da madrugada	funcionário de saída copiando projetos
Acesso às 3h da manhã	o plantonista de serviço	a conta do RH, que só trabalha de dia
Um site consultado 500 vezes	o programa de atualização	um programa espião chamando o seu dono

Detecção: o alarme que segue uma regra

Uma regra é um combinado escrito antes: se acontecer isto, avise.

NO TRÂNSITO

Passou de 60 km/h?

Multa.

O radar não pensa. Aplica a regra a todo carro.

NA EMPRESA

A mesma conta errou a senha 5 vezes em 1 minuto?

Alerta.

A regra roda sozinha, sobre cada evento.

Como uma regra funciona dentro da empresa

O sistema compara cada evento com as regras. Quando uma bate, nasce um alerta para alguém analisar.



Do combinado em português ao sistema

1 · EM PORTUGUÊS

Se a mesma conta errar a senha 5 vezes em 1 minuto, avise.

2 · COMO LÓGICA

```
contar falhas de login por conta, a cada 1 minuto
se a contagem passar de 5 → criar alerta
```

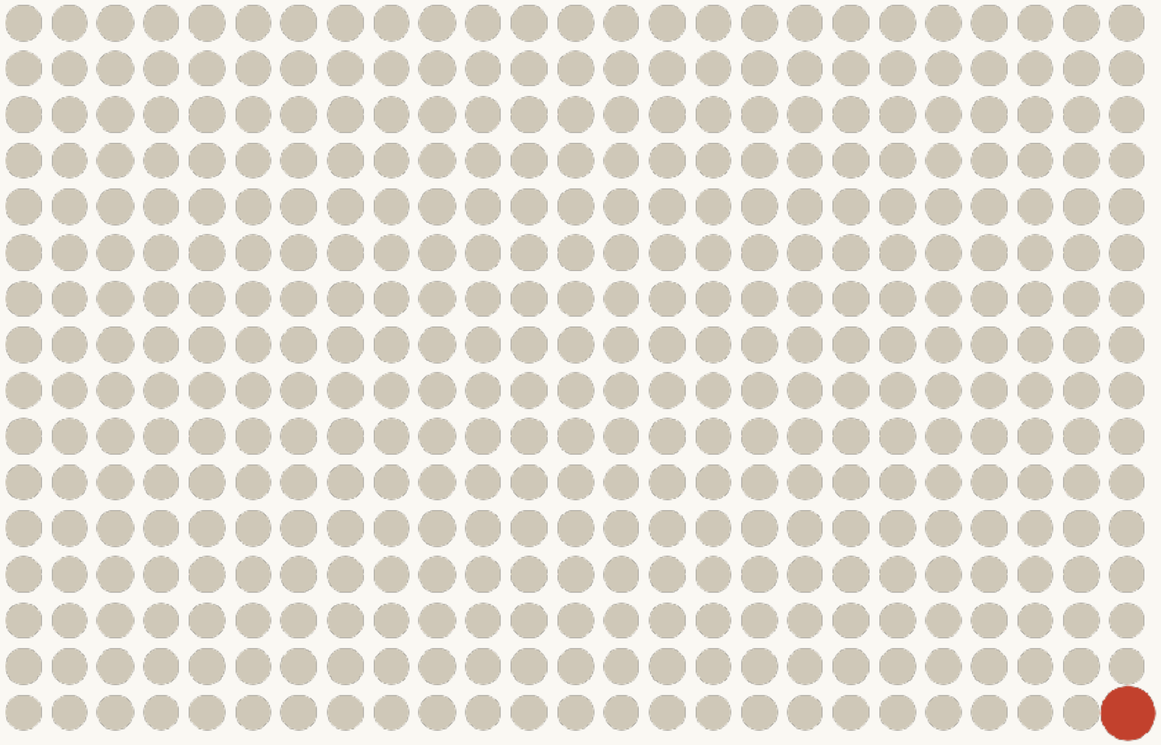
3 · DENTRO DO SISTEMA

```
event.outcome:"failure" | contar por user.name | janela 1 min |
limite 5
```

A equipe escreve uma vez. O sistema aplica em todos os eventos, o tempo todo.

Quando o alarme toca o tempo todo, ninguém mais escuta

Fadiga de alertas: tantos avisos falsos que os verdadeiros passam despercebidos, como o alarme de carro que dispara toda noite.



24 a 134 mil

alertas por dia num centro de segurança

0,01%

eram ataques de verdade: 1 a cada 10 mil

Yang et al., USENIX Security 2024: quatro anos de alertas de um centro de operações.

Target, 2013: o alarme tocou, e ninguém agiu

A rede de lojas dos EUA perdeu dados de até 110 milhões de clientes.



ANTES DE NOV. 2013

Os invasores roubam a senha de um fornecedor de ar-condicionado.



NOV. 2013

Com ela, entram na rede da Target.



NOV.–DEZ.

A ferramenta de segurança dispara alertas. A equipe não age.



DEZ. 2013

Dados de até 110 milhões de clientes saem da empresa.

Quando o barulho é a própria arma

Em 2014, os reguladores dos bancos dos EUA avisaram: criminosos usam ataques de tráfego para distrair a equipe enquanto fazem transferências fraudulentas.



Na porta da frente

Uma multidão falsa de acessos entope o site e as telas da equipe.

ATAQUE DE NEGAÇÃO DE SERVIÇO (DDOS)

+



Pela porta dos fundos

Enquanto todos olham para o tumulto, os dados saem em silêncio.

ROUBO DE DADOS

O que nenhuma regra pega

O invasor que usa uma senha verdadeira e parece um funcionário.

O ataque lento, que fica abaixo de todo limite.

A técnica nova, que ainda não tem regra escrita.

Para isso existe a caça.

Caçar é procurar o invasor antes de qualquer alarme.

Threat hunting, ou caça a ameaças.



O alarme e o detetive

	DETECÇÃO · O ALARME	CAÇA · O DETETIVE
QUANDO AGE	espera o evento combinado	vai procurar, sem esperar aviso
PONTO DE PARTIDA	uma regra escrita antes	uma suspeita sobre o atacante
O QUE ENTREGA	um alerta	uma descoberta, e às vezes uma regra nova
PONTO CEGO	o que ninguém previu	depende de quem faz a pergunta

Toda caçada começa com uma suspeita que se pode testar

Os especialistas chamam a suspeita de hipótese.

Se o atacante fez X, os registros devem mostrar Y.

SUSPEITA

Alguém adivinhou uma senha da VPN.

ENTÃO PROCURE

Uma mesma origem tentando **muitas contas diferentes** e, depois, conseguindo entrar.

SUSPEITA

Um programa espião se esconde num computador.

ENTÃO PROCURE

Um endereço chamado **em intervalos regulares**, por **um computador só**.

Quem caça bem aprendeu fazendo

22

caçadores de ameaças entrevistados

O que mais pesa é a experiência: saber o que é normal naquele ambiente e qual pergunta fazer.

sem roteiro

é como muitas equipes caçam

Por isso, hoje, um método: a mesma sequência de perguntas nos três casos.

Badva et al., USENIX Security 2024; Masam e Davis, USENIX Security 2024.

MITRE ATT&CK: o dicionário dos ataques

Um catálogo público, mantido pela organização sem fins lucrativos MITRE, que dá nome a cada objetivo do atacante e a cada jeito de alcançá-lo.

Entrar	Executar	Ficar	Esconder-se	Descobrir	Levar dados
Adivinhar senhas `T1110`	Programa malicioso	Conta nova	Nome de programa legítimo	Mapear grupos e contas	Enviar para fora
E-mail com anexo	Comando escondido	Tarefa agendada	Apagar rastros	Varrer a rede	Canal disfarçado
Senha válida roubada					

Tática é o objetivo (entrar, ficar, levar dados). Técnica é o jeito. O catálogo real tem 14 táticas e centenas de técnicas.



CTF: capture a bandeira

Competição de segurança em que cada desafio esconde uma resposta, a bandeira (flag), que prova que você resolveu.



CTF clássico

Desafios de **quebrar**: invadir um sistema, decifrar um código, achar uma falha.

`flag{3nc0ntr31_4_f4lh4}`

A bandeira é um texto escondido que prova que você chegou lá.



Caça a ameaças

Desafios de **investigar**: o ataque já aconteceu, e a prova está nos registros.

`flag{203.0.113.77}`

A bandeira é a resposta da investigação: quem, de onde, quando.

Hikari: caça a ameaças com placar

Cada desafio é uma pergunta sobre um incidente. A resposta está nos registros. O formato de CTF transforma a investigação em jogo: pontos, fases e placar.



Parte 2

A ferramenta



SIEM: a central onde todos os registros se encontram

Como um buscador da internet, só que dos eventos da empresa.

VPN
a porta de entrada remota

Logins
quem entrou em cada servidor

DNS
os endereços que cada máquina consultou

EDR
a câmera dentro de cada computador

Firewall
a portaria da rede

Arquivos
o que foi aberto, criado ou renomeado

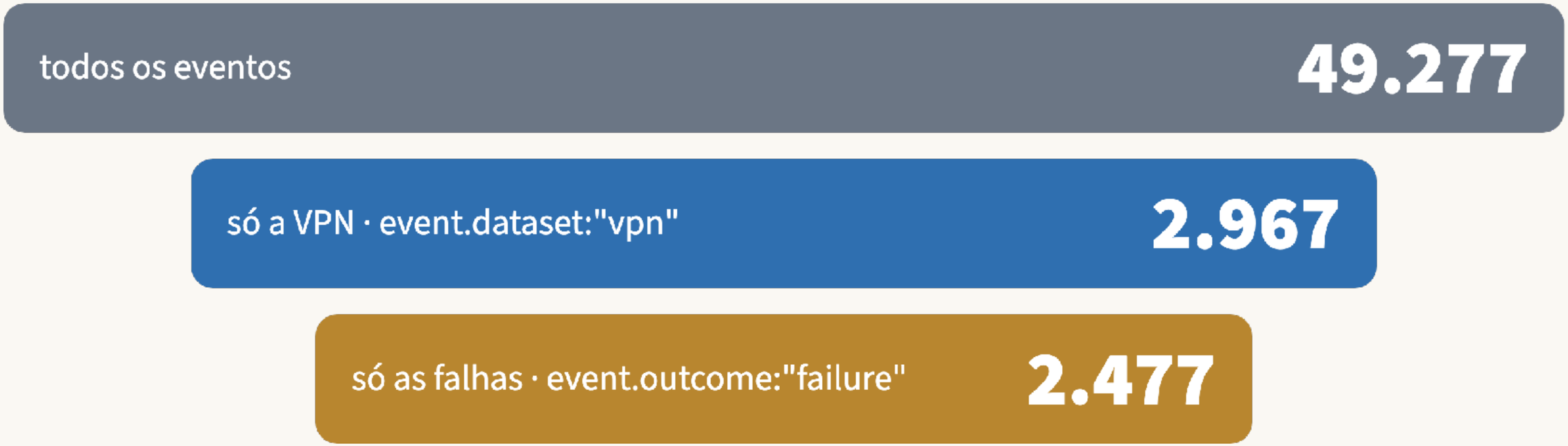
→

SIEM

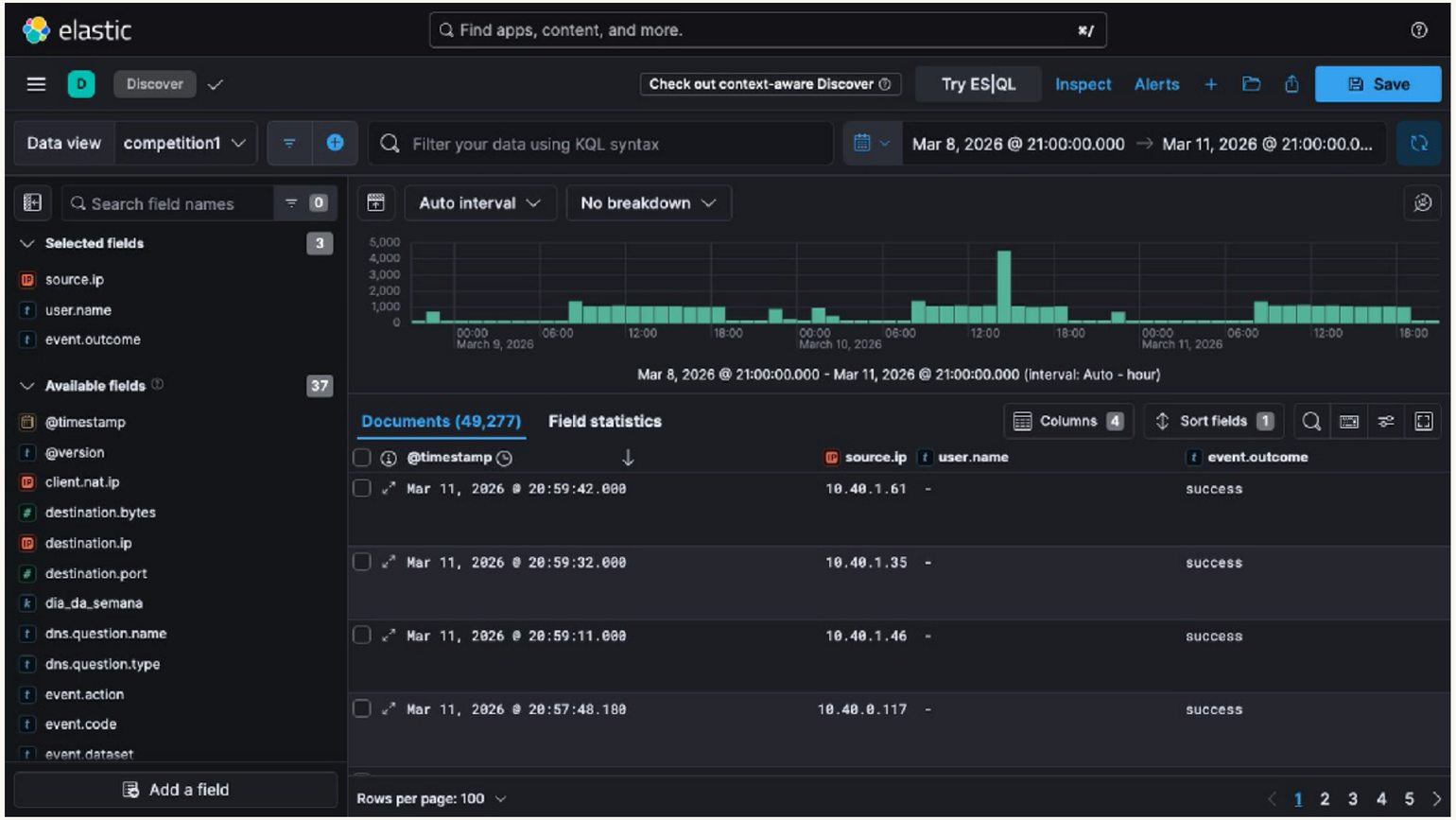
Junta todos os registros num lugar só e deixa pesquisar.

Filtrar é peneirar

Como os filtros de uma loja on-line: tamanho, cor, preço. Aqui: tipo de evento, resultado, origem.



Veja: o filtro em ação



1 · Escreva o filtro na caixa de busca.

2 · Aperte Enter.

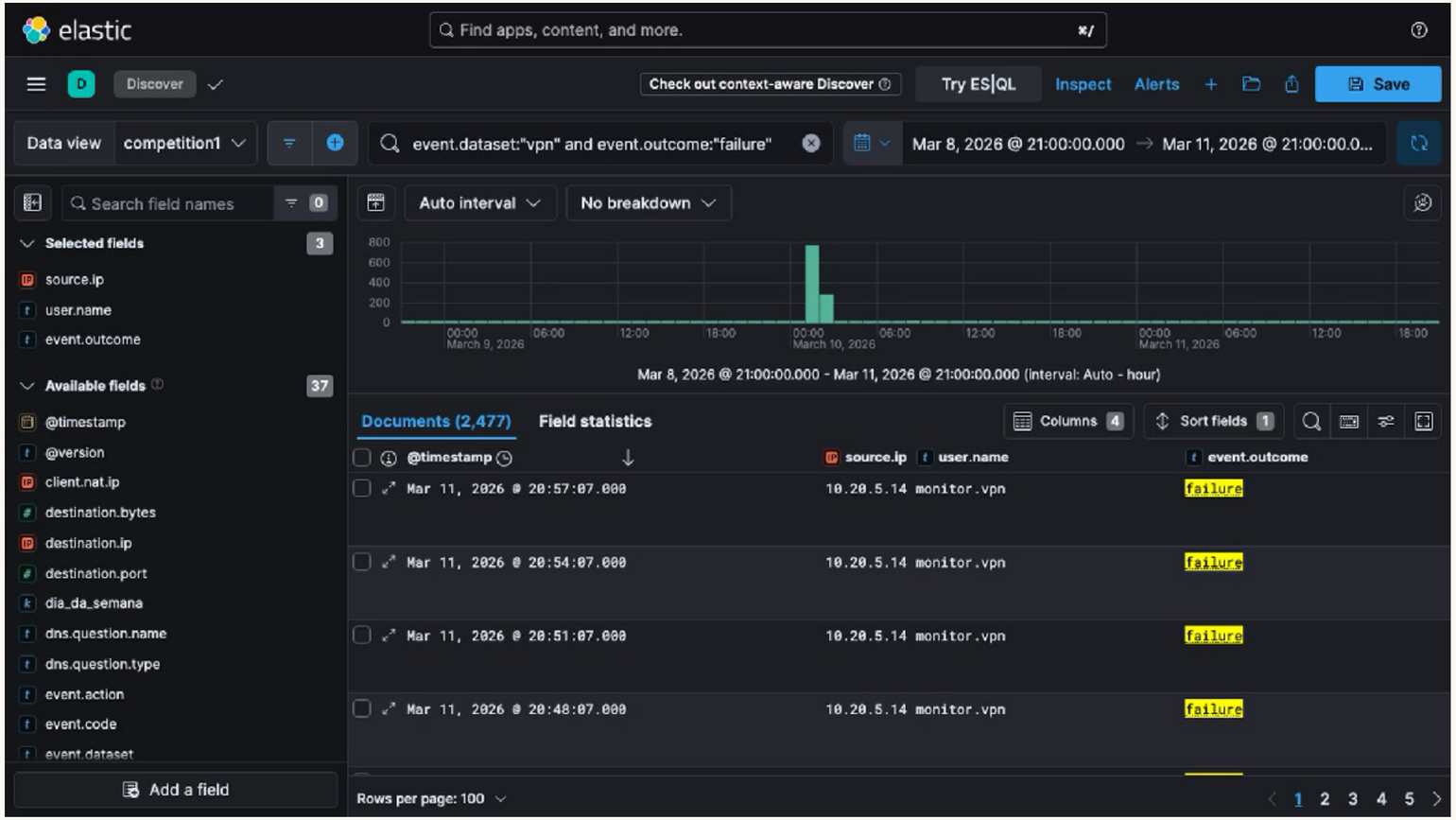
Repare no número de eventos encolhendo: 49.277 → 2.967 → 2.477.

Contar é agrupar

Como a apuração de uma eleição: quantos votos teve cada candidato? Aqui: quantas falhas teve cada origem, e quantas contas diferentes cada origem tentou.

ORIGEM	FALHAS	CONTAS DIFERENTES
10.20.5.14	1.440	1
203.0.113.77	1.026	62
177.39.199.144	2	2

Veja: quem mais aparece



1 · Clique no nome de um campo, como source.ip.

2 · O Kibana mostra os valores mais frequentes.

Top values = os mais frequentes.

A maior contagem pode ser uma isca

A PRIMEIRA IDEIA

Quem mais falhou?

`10.20.5.14 · 1.440 falhas`

Mas todas numa conta só, `monitor.vpn`: um robô de monitoramento com senha velha.

É a isca.

A PERGUNTA CERTA

Quem tentou mais contas diferentes?

`203.0.113.77 · 62 contas`

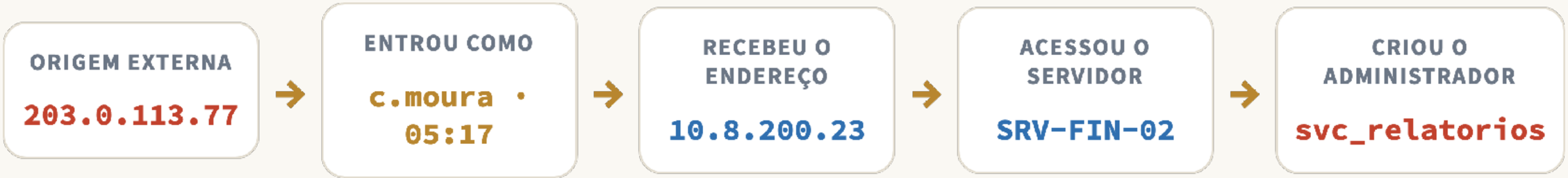
E uma delas, `c.moura`, entrou às 05:17.

É o invasor.

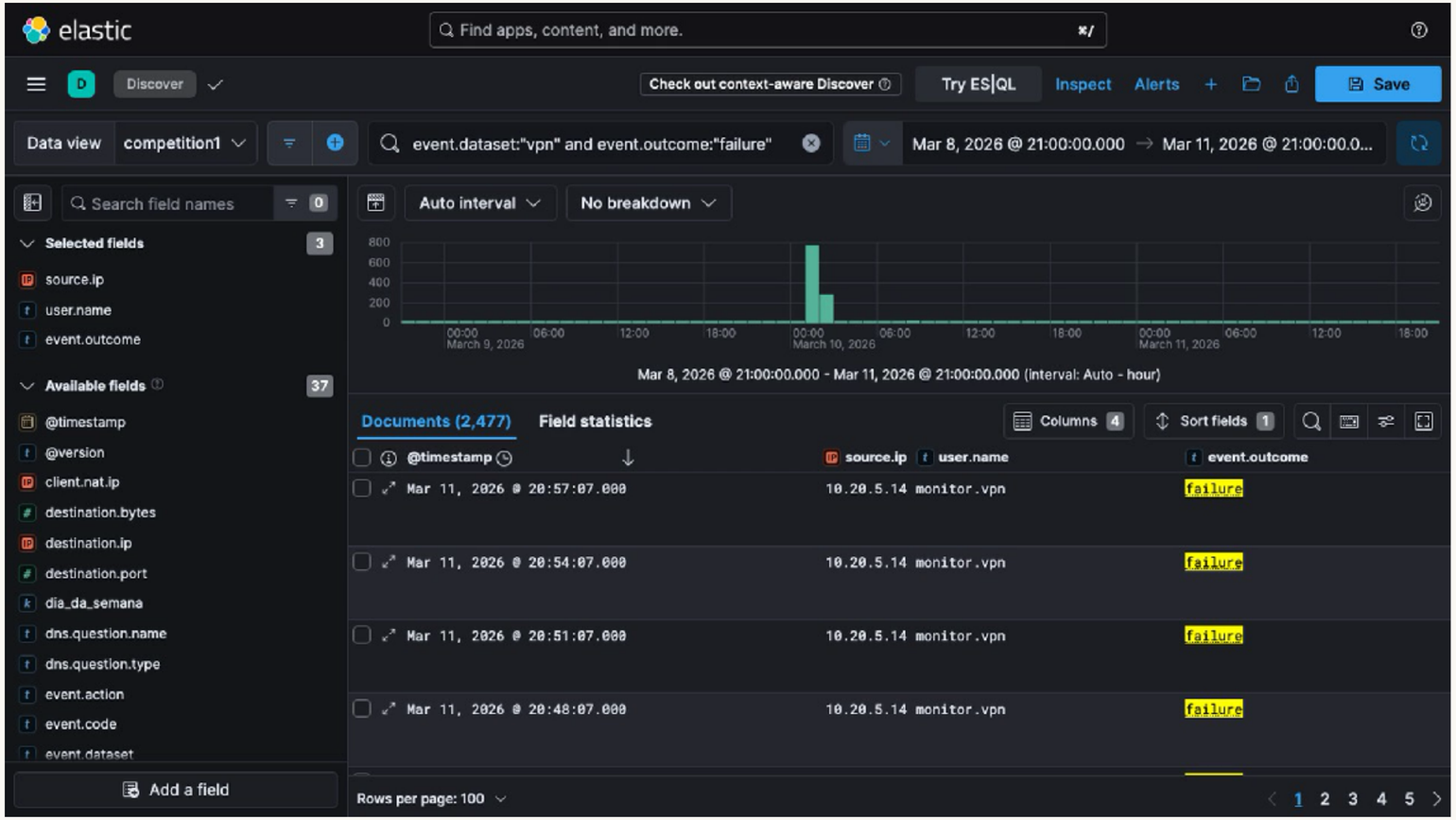


Seguir a pista: o valor achado vira o próximo filtro

Como seguir uma placa de carro de câmera em câmera.



Veja: seguindo a pista



1 · Filtre pela origem suspeita.

2 · Veja as contas que ela tentou.

3 · Filtre só os sucessos: a sessão que entrou.

Parte 3

Mãos na massa



Aurora Telecom: a empresa do exercício

Uma operadora de telecomunicações que não existe. Três dias de registros reais na forma, inventados no conteúdo. Algo aconteceu nesses dias: a sua tarefa é descobrir o quê.

120
computadores

3 dias
de registros

6 fontes
de eventos

49.277
eventos



Passo 1 · Crie a sua conta no treino



Abra o navegador em:

`treino.hikari.seg.br/register`

Preencha nome, e-mail e senha (1) ou use Cadastrar com Google (2).

Passo 2 · Crie a sua equipe

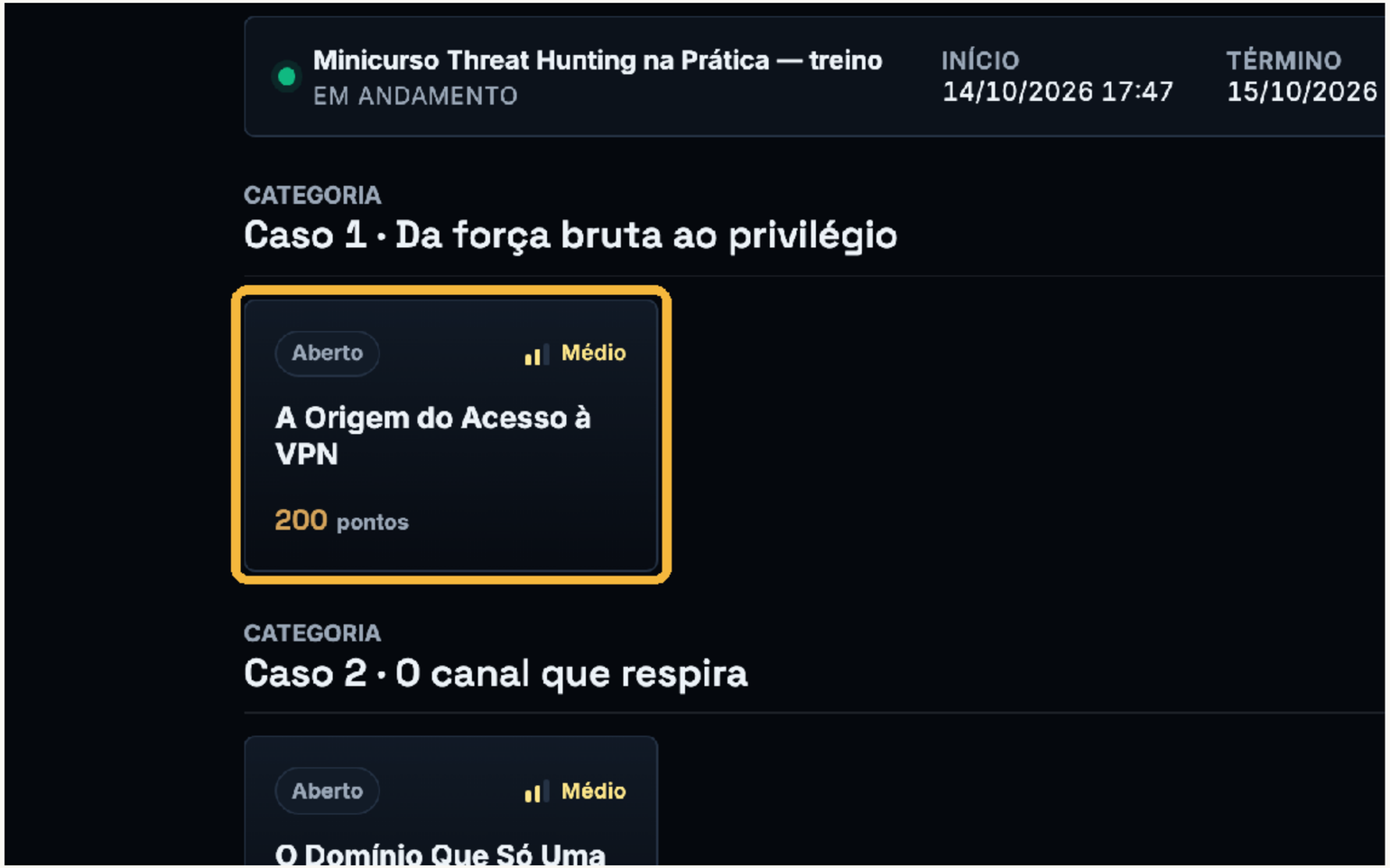


Na tela Equipe, clique em Criar equipe, inclusive individual (1) e dê um nome.

No treino, cada pessoa cria a própria equipe.

Na Arena, uma pessoa cria a equipe; as outras clicam em Encontrar equipe (2) e pedem para entrar. O capitão aprova.

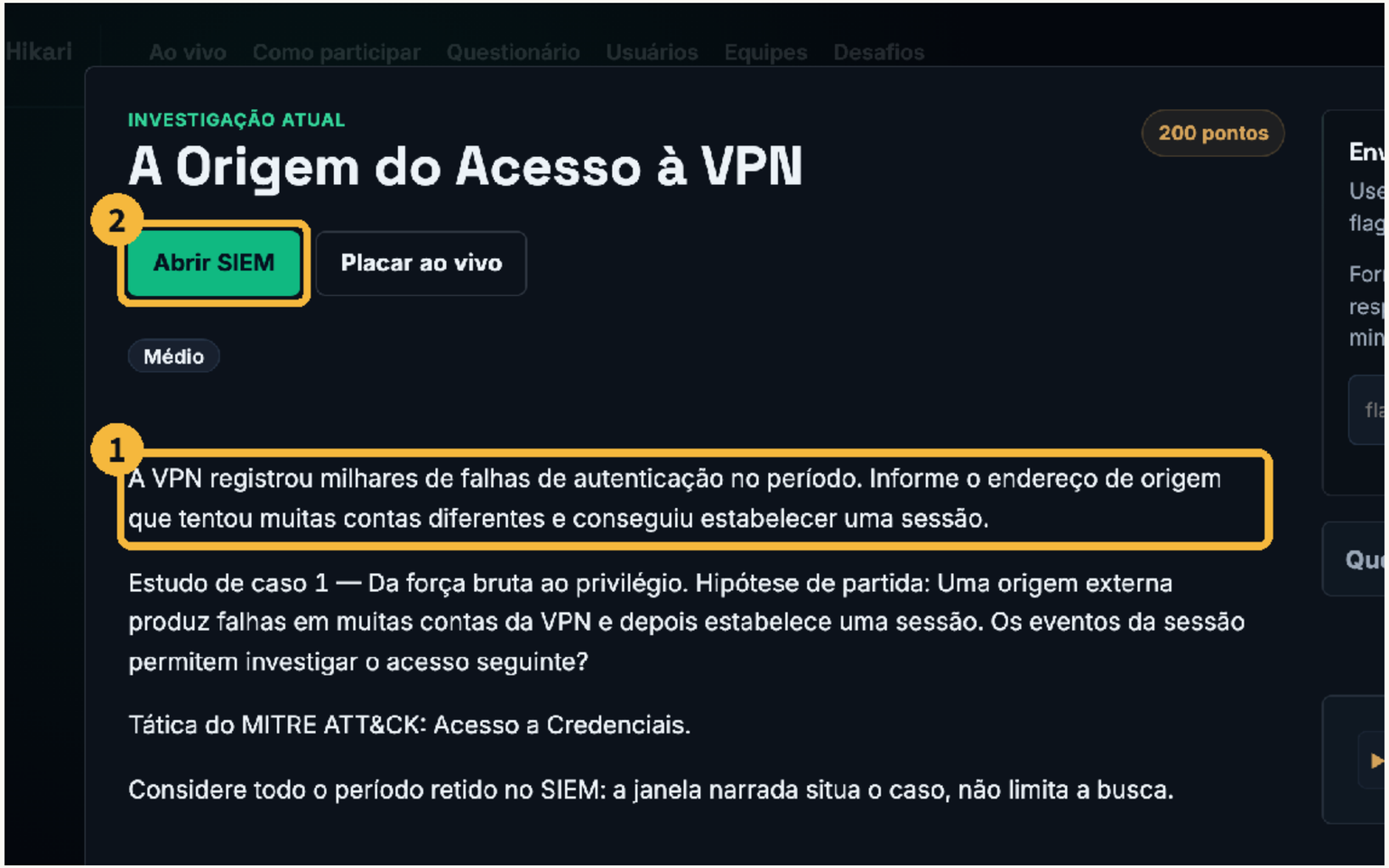
Passo 3 · Abra o primeiro desafio



No grupo Caso 1, clique em “A Origem do Acesso à VPN”.

Os outros casos ficam para depois.

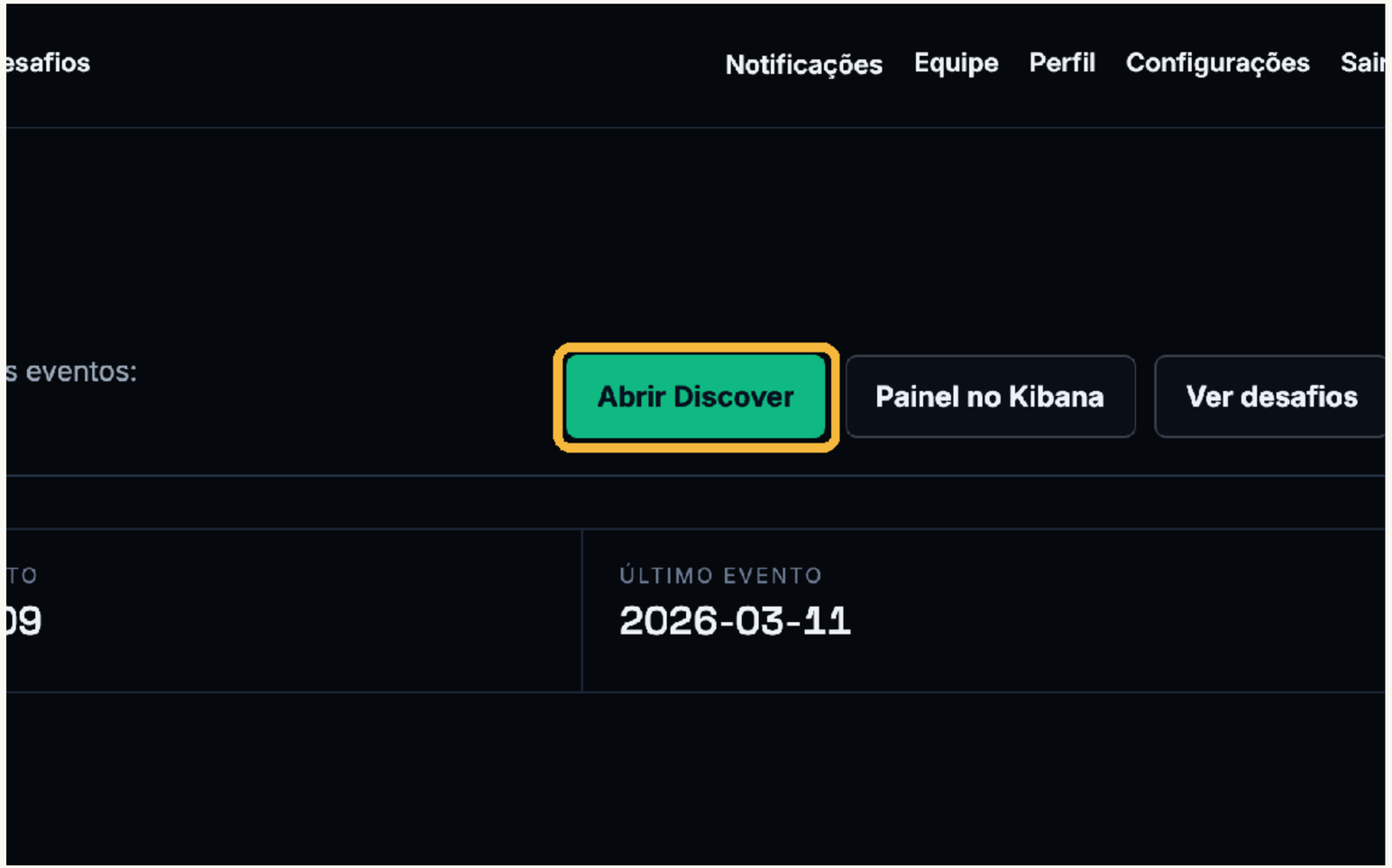
Passo 4 · Leia a pergunta e abra o SIEM



1 · A pergunta: qual origem tentou muitas contas diferentes e conseguiu entrar?

2 · Clique em Abrir SIEM.

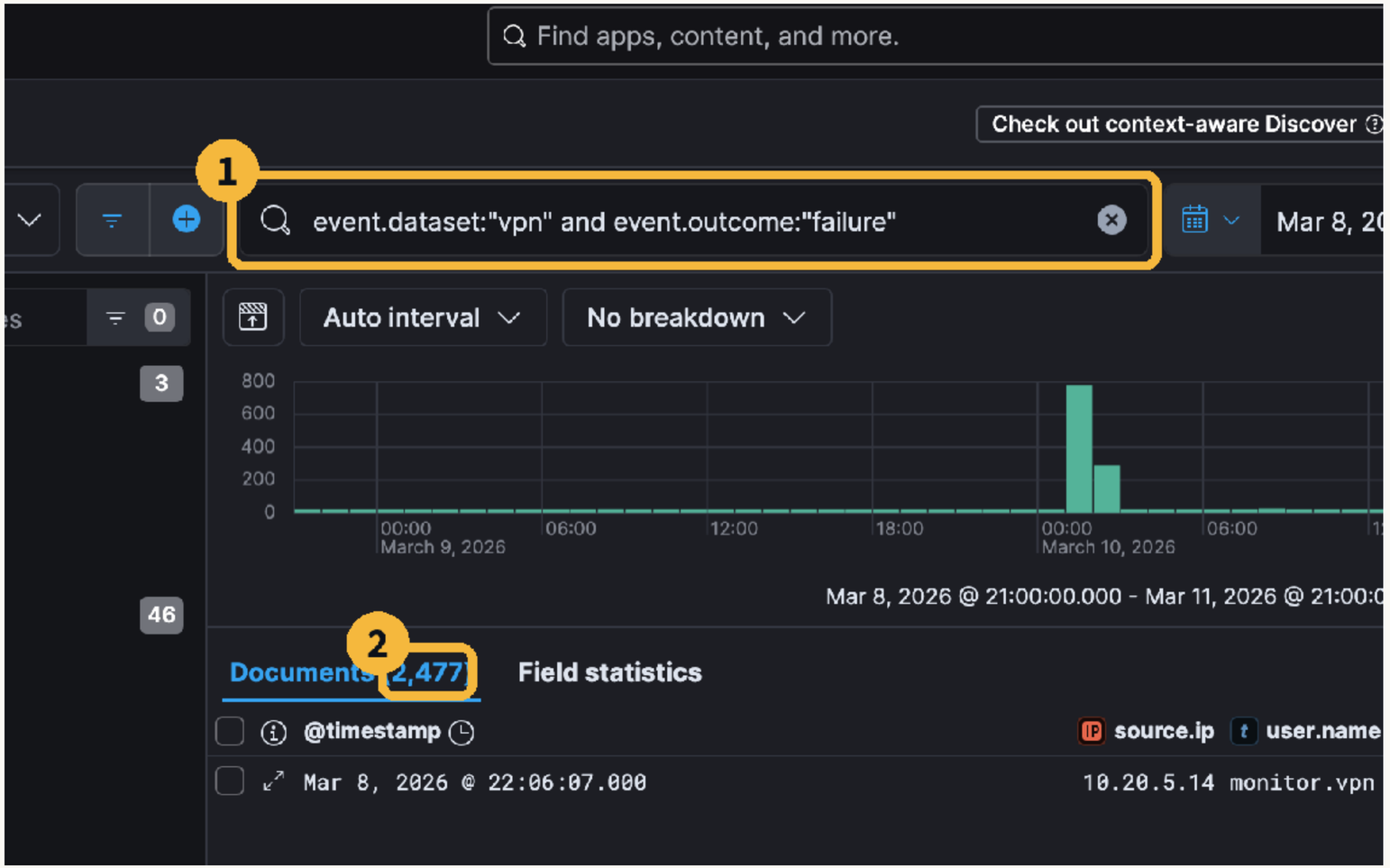
Passo 5 · Entre na busca



Na página do SIEM, clique em Abrir Discover.

O Discover é a tela de busca do Kibana.

Passo 6 · Filtre as falhas da VPN

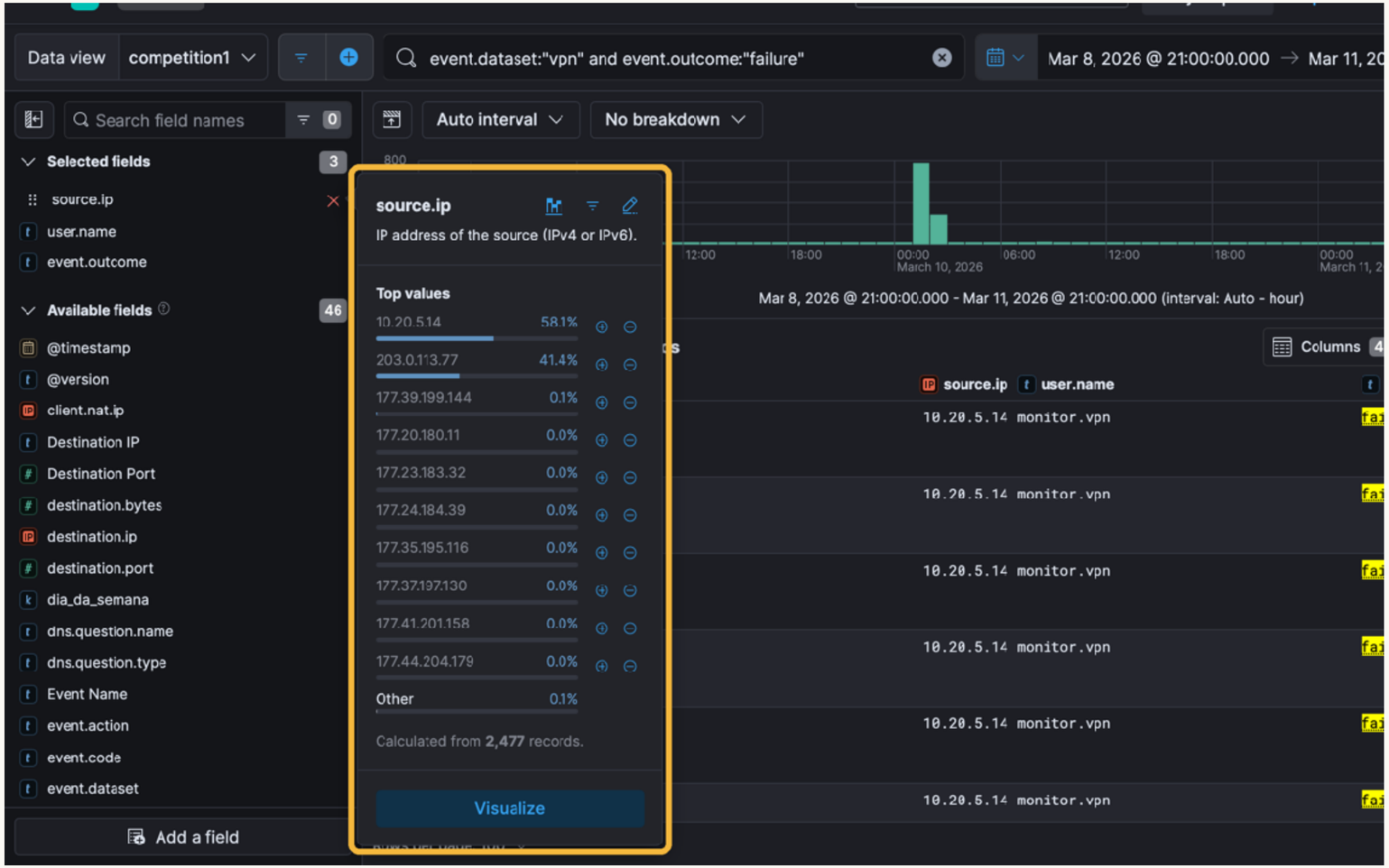


1 · Escreva na caixa de busca e aperte Enter:

```
event.dataset:"vpn" and
event.outcome:"failure"
```

2 · Confira: sobram 2.477 eventos.

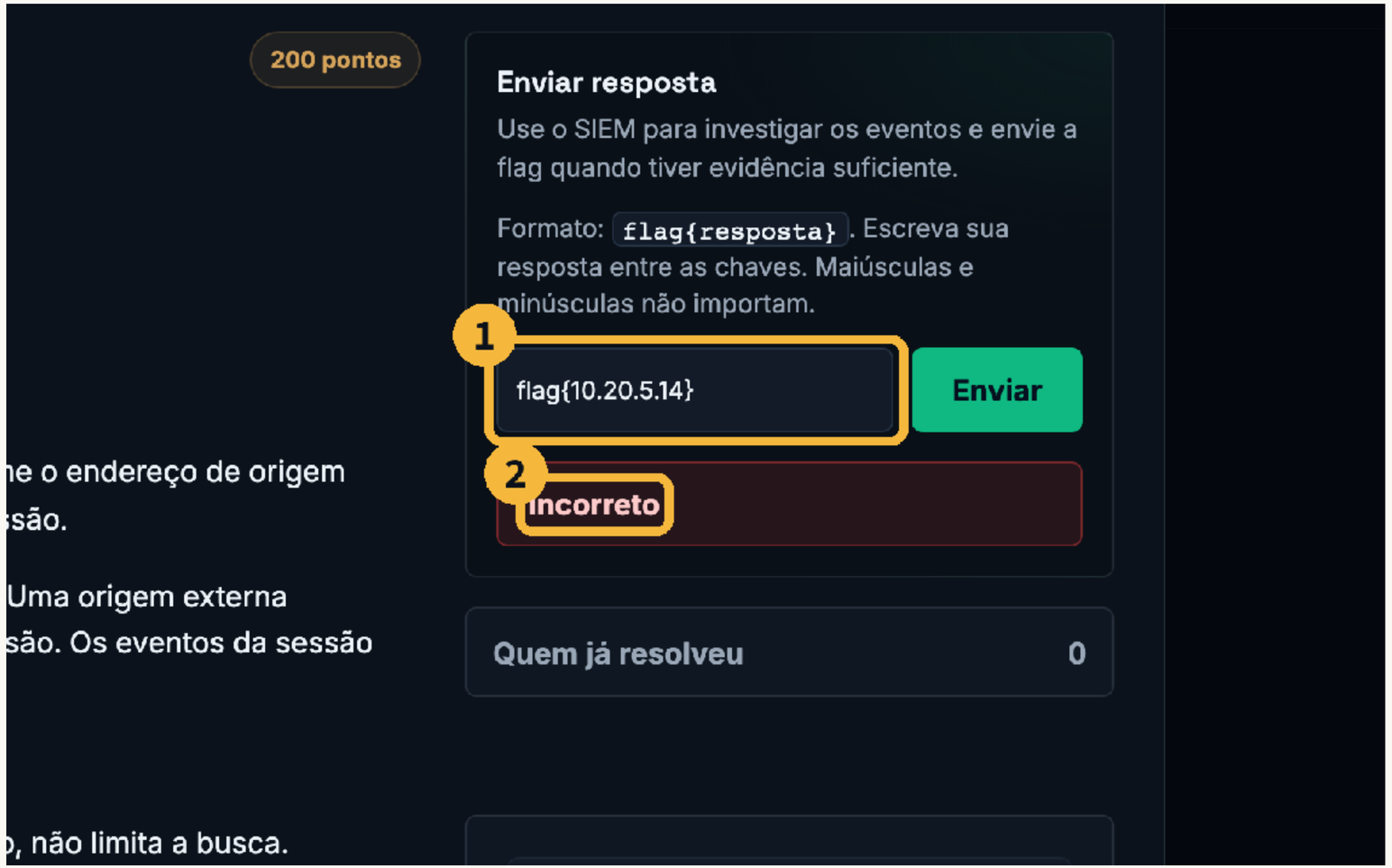
Passo 7 · Quem mais falhou?



Na coluna da esquerda, clique em source.ip.

O primeiro da lista, 10.20.5.14, tem mais da metade das falhas.

Passo 8 · Responda e veja o que acontece



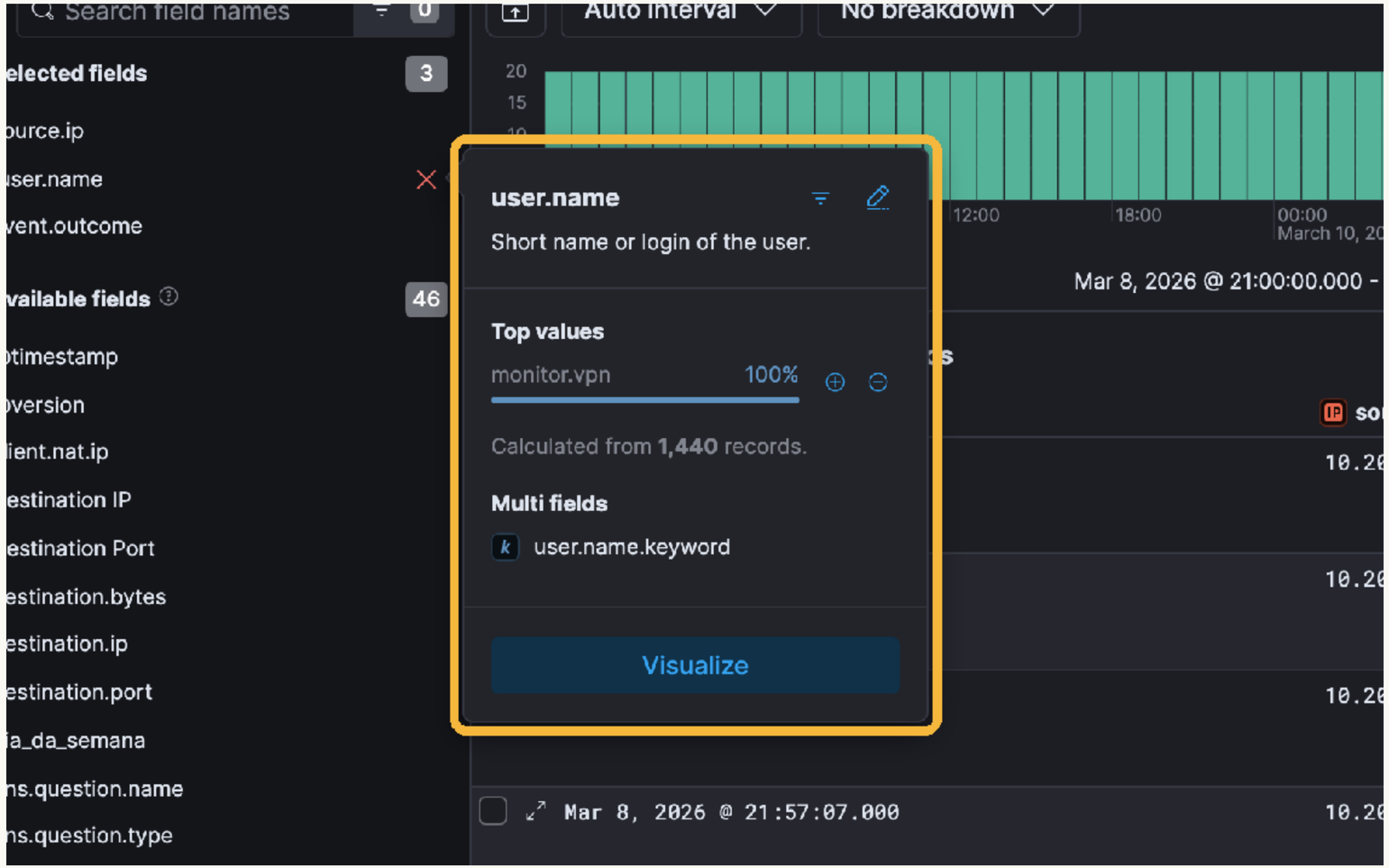
1 · Na janela do desafio, escreva a resposta e clique em Enviar:

`flag{10.20.5.14}`

A resposta vai sempre entre flag{ e }, aqui e na Arena. Sem isso, dá Incorreto.

2 · Incorreto. Por quê?

Passo 9 · Confira quantas contas cada origem tentou



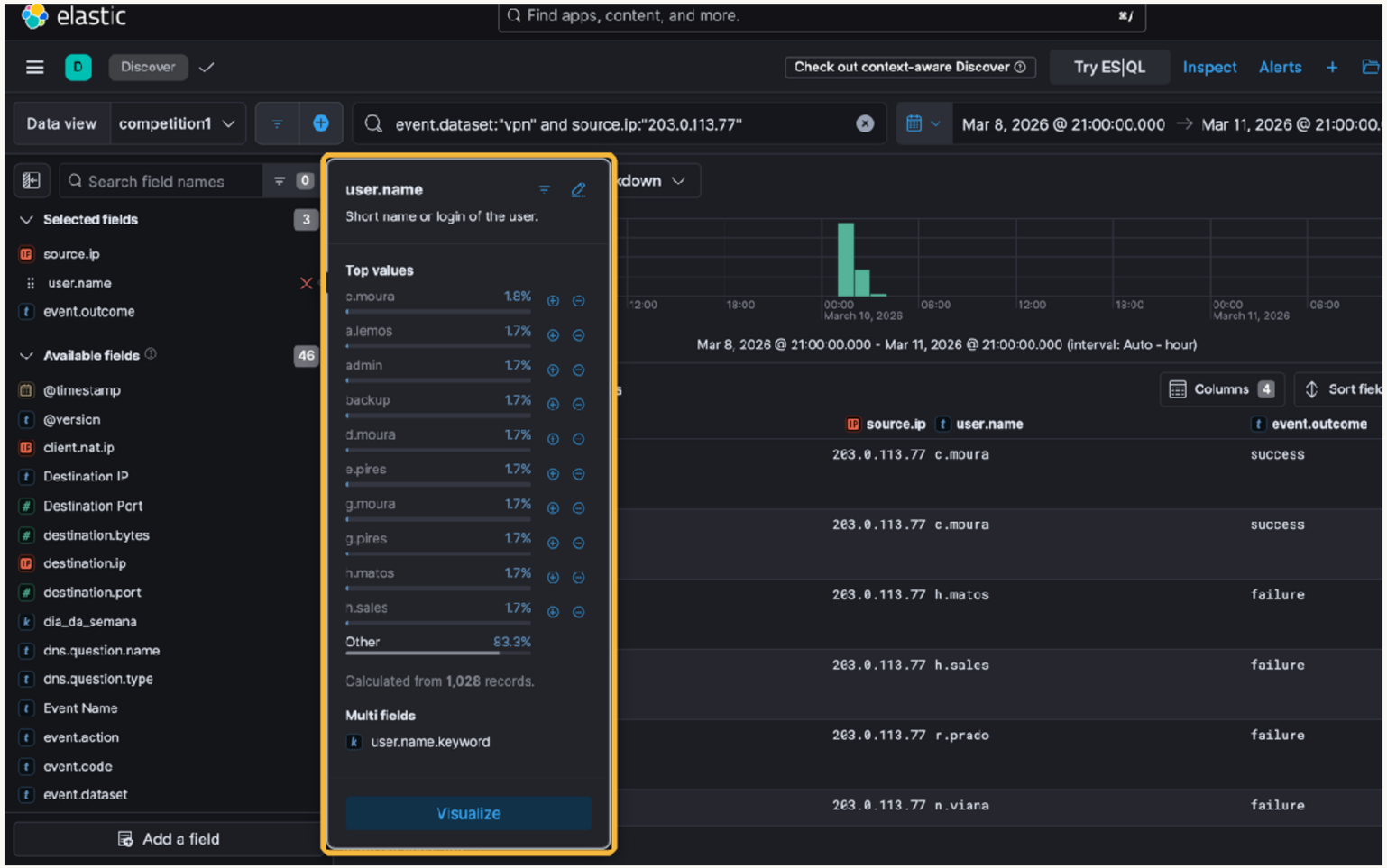
Busque:

```
event.dataset:"vpn" and
source.ip:"10.20.5.14"
```

Clique em user.name.

Uma conta só: monitor.vpn, um robô de monitoramento com senha velha.

Passo 10 · Agora, a outra origem



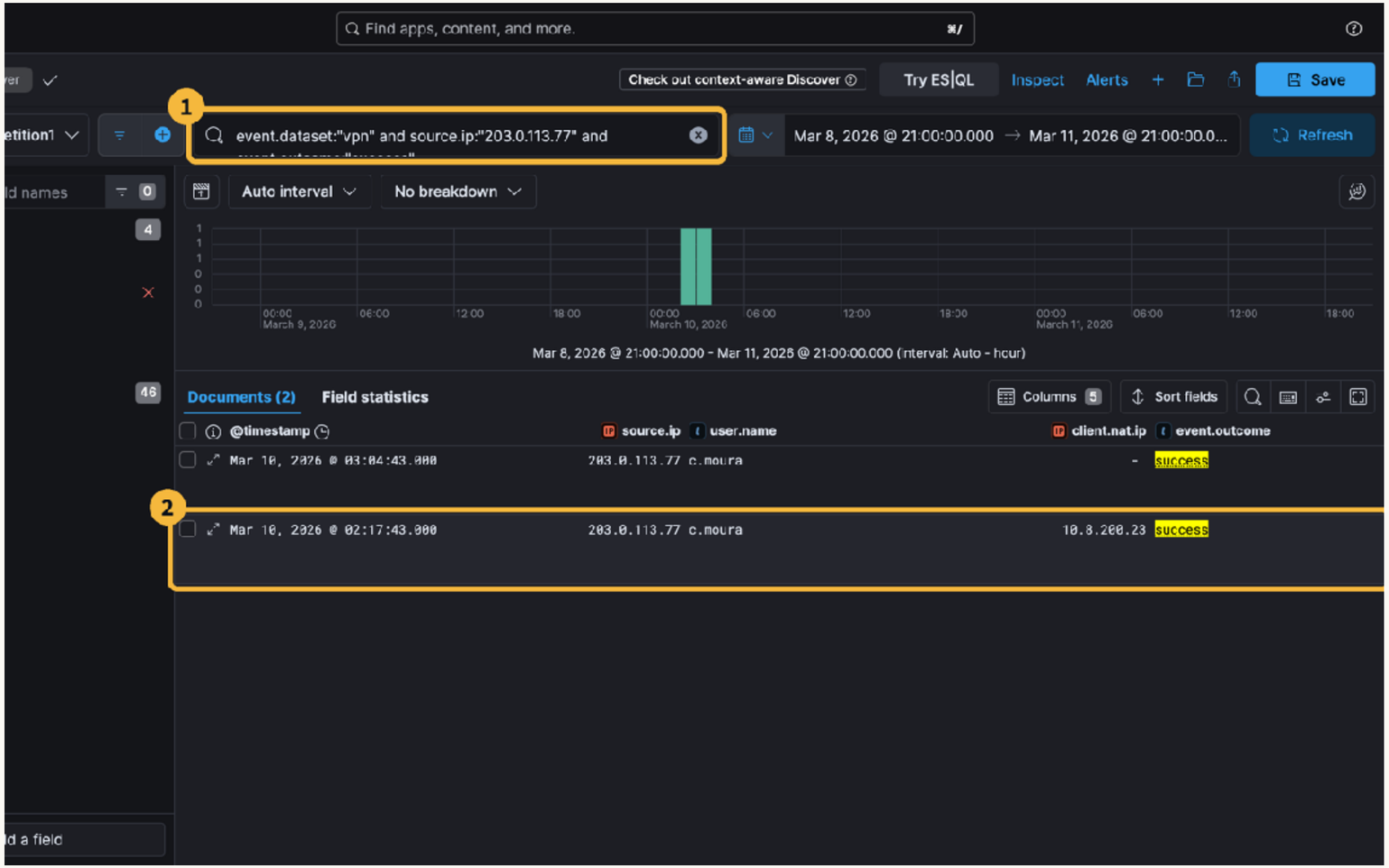
Busque:

```
event.dataset:"vpn" and
source.ip:"203.0.113.77"
```

Clique em user.name.

Dezenas de contas diferentes: 62.
Alguém está adivinhando senhas.

Passo 11 · Ela conseguiu entrar?

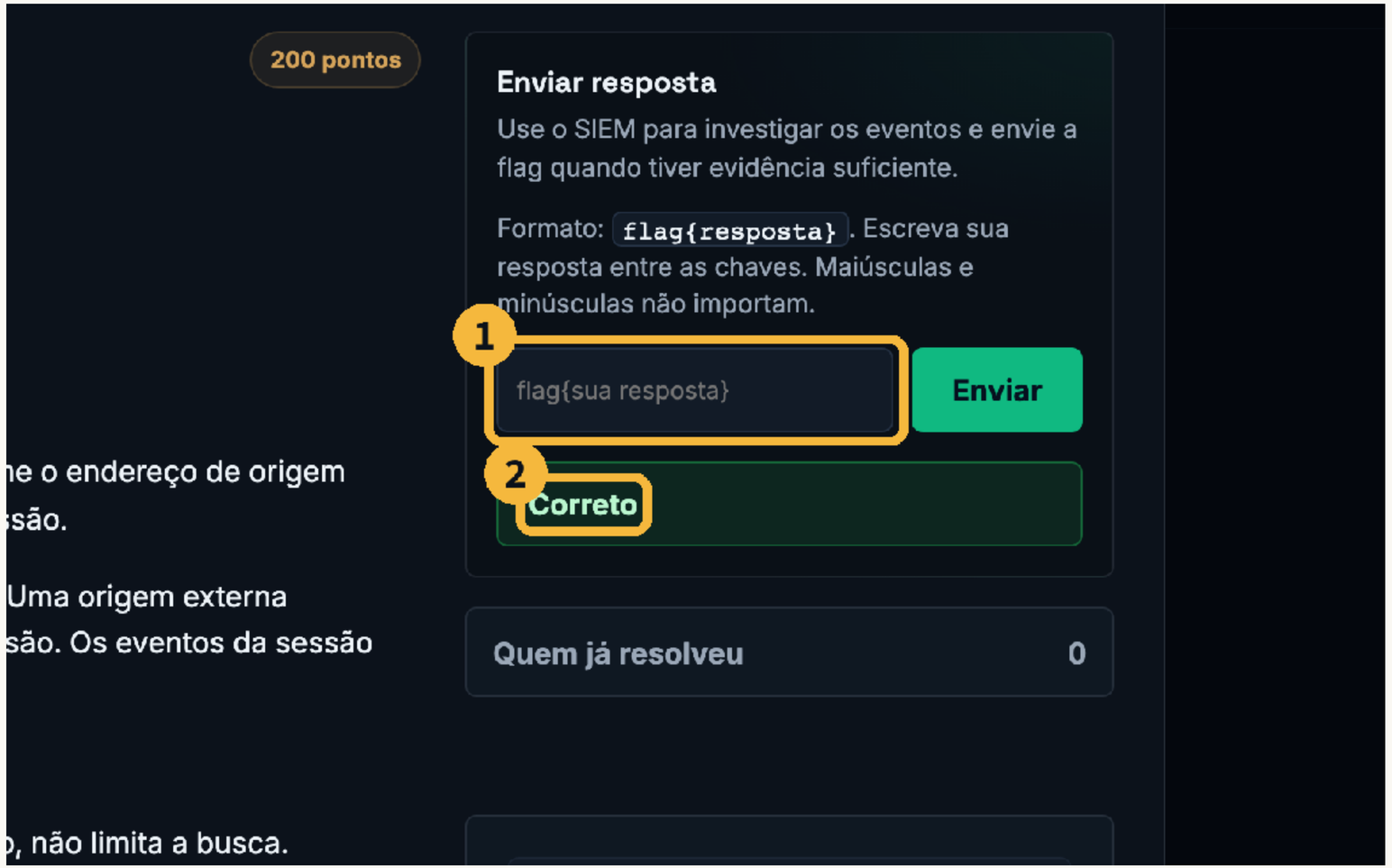


Acrescente ao filtro:

```
and event.outcome:"success"
```

Sim: a conta c.moura entrou, e a VPN entregou a ela o endereço interno 10.8.200.23.

Passo 12 · Responda de novo



Escreva a resposta e clique em Enviar:

`flag{203.0.113.77}`

Correto. Você encontrou o invasor.

O que você acabou de fazer

Suspeitou: alguém adivinhou senhas da VPN.

Filtrou: só as falhas da VPN.

Desconfiou do número mais alto e contou o que importava: contas diferentes.

Confirmou: a origem que tentou 62 contas entrou como c.moura.

Isso é threat hunting.

Continue sozinho: os próximos desafios do caso 1

Acertar abre novos desafios: qual conta cedeu, o minuto zero, a ponte para dentro, o novo administrador.

Use a pista: o endereço interno vira filtro nos logins dos servidores.

```
event.dataset:"auth" and source.ip:"10.8.200.23"
```

Travou? Abra a dica: no treino, a equipe começa com 300 pontos para isso. Na Arena, a dica custa pontos que a equipe conquistou.

Caso 2 · O domínio que só uma máquina conhece

Suspeita: um programa espião chama o seu dono a intervalos regulares.

Então procure: um endereço consultado muitas vezes, por um computador só.

Comece por esta busca e clique em dns.question.name:

```
event.dataset:"dns"
```

A isca: o endereço mais consultado é a atualização que todos os computadores fazem.

Caso 3 · Quem mapeou o diretório

Suspeita: antes do estrago, o invasor faz um mapa dos grupos e das contas da empresa.

Então procure: uma conta que consulta muitos grupos diferentes em pouco tempo.

Comece por esta busca e clique em user.name:

```
event.dataset:"auth" and event.code:"4799"
```

A isca: o inventário automático consulta sempre os mesmos três grupos.

Caso 4 · Ponte para a Arena: o mesmo método, outro formato

Na Arena, os alertas vêm de outro SIEM, o QRadar. Os nomes dos campos têm espaço: Event Name, Source IP, Username.

Campo com espaço vai entre aspas, como o valor:

```
"Event Name":"SSH Brute Force"
```

No treino, o Caso 4 traz alertas da Aurora nesse formato. Comece por esta busca:

```
event.dataset:"qradar"
```

Caso 4 · Quatro perguntas que a Arena repete

O mais comum: clique no campo Event Name; o primeiro da lista é o mais frequente.

Filtrar e contar: filtre o alerta, entre aspas, e clique em Source IP.

O primeiro no tempo: clique no título @timestamp para ordenar do mais antigo para o mais novo.

O mais raro: tire o comum da frente com not, um de cada vez, até sobrar um.

```
event.dataset:"qradar" and not "Event Name":"Firewall Deny"
```

Fechamento

Para levar



O método em quatro passos

1

Suspeite

Escreva o que o atacante teria feito.

2

Filtre

Fique só com os eventos que importam.

3

Conte o que importa

Escolha a medida que separa o normal do estranho.

4

Confirme e declare

Siga a pista até o fim e diga o que os registros não mostram.

Hoje à tarde, a mesma plataforma vira arena.

1ª Ciber Week Brisanet · Arena de Desafios Técnicos · 12h às 18h · equipes de até 5 pessoas · hikari.seg.br

Crie conta e equipe de novo, com os mesmos passos: as do treino não valem na Arena.

Material e contato

Apresentação, capítulo e cadernos de prática:

`sidneibarbieri.github.io/hikari/minicurso`

Contato:

`sidneibarbieri.github.io`

Problemas durante a Arena? Fale com o time do Hikari

Sala de apoio no Google Meet, aberta hoje das 9h às 20h:

`meet.google.com/oqz-nnti-yoe`

Entre com a câmera ou só pelo chat e diga o nome da sua equipe.

Antes de chamar: a resposta vai entre flag{ e }, e o SIEM abre às 12h.